

Allstar aims to fix vulnerabilities in open source projects



GitHub and Google have announced the launch of Allstar, an app that provides automated continuous enforcement of security best practices for GitHub projects. Created by Google and the Open Source Security Foundation (OpenSSF), Allstar can check for security policy adherence, set enforcement actions, and enact those enforcements when triggered by a setting or file change in a repository. The aim is to help the open source community reduce security risks.

Allstar is a companion to Security Scorecards, a tool that assesses risk to a repository and its dependencies. While Scorecards checks important heuristics like whether the project uses branch protection, cryptographically signs release artifacts, or requires code review, Allstar allows maintainers to opt for automated enforcement of specific checks. If a repository fails a particular check that you enable, Allstar intervenes to make the necessary changes to remediate the issue, avoiding the extra effort of regular manual fixes.

“In short, Security Scorecards helps you measure your current security posture against where you want to be; Allstar helps you get there,” reads a company blog.

Open source projects are often vulnerable to security risks. Allstar is said to work continuously, checking expected GitHub API states like repository settings and branch settings against security policies, and applying enforcement actions. On detecting a vulnerability, it puts enforcement actions in place, such as filing issues and changing the project settings. For example, Allstar will spot and respond to policy violations if a developer temporarily disables branch protections to commit a malicious change before re-enabling the protections.

Tech giants team up to launch the eBPF Foundation

Microsoft, Facebook, Netflix, Google, and its startup Isovalent, have united to launch the eBPF Foundation, designed to motivate ‘revolutionary’ technology that will implement observability, security and networking functionality.

eBPF (extended Berkeley Packet Filter) is a technology with origins in the Linux kernel that can run sandboxed programs in an operating system kernel without having to change any load modules and open source codes.

By making the OS kernel programmable, infrastructure software can leverage existing layers, making them more intelligent and scalable, without continuing to add additional layers of complexity to the system.

Tigera launches partner programme

Tigera has launched a worldwide partner programme to meet demand from the growing adoption of containers, Kubernetes, and microservices, which has created security and observability challenges for enterprises. Tigera’s Calico Cloud and Calico Enterprise provide automated capabilities that can be used to secure, observe, and resolve performance issues and troubleshoot microservices.

Tigera will provide partners with sales leads, incentives, technical assistance, and product education. Partners can register deals and receive compensation for referral sales. The programme is aimed at all types of partners — solution provider resellers, systems integrators, consultants, and distributors — that have competencies in AWS, Azure, GKE, Red Hat OpenShift, and Suse Rancher Kubernetes, with practices related to DevOps, microservices, networking, and security.



Amit Gupta, vice president of business development and product management, Tigera, said, “We want to help partners evolve their offerings to capitalise on the growth of containers, Kubernetes, and microservices opportunities, in order to grow their business and expand their value to customers. Now, we’re formalizing what has been an *ad hoc* network of partners as we see increasing inbound activity from partners of all types. This builds on our existing relationships with partners in North America and Europe that include AWS, Azure, Fortinet, Red Hat, and Suse Rancher, where we’re already working together on customer engagements.”